CareLoop trust zones, the authority gate, and the independent read-back

The model proposes. Deterministic code authorises. A separate read of an external system confirms what happened.

UNTRUSTED · CONTROLLED · TRUSTED · work and effects → · independent read-back ⇢ · LLM one of exactly two model calls, and neither holds authority

UNTRUSTED what the world sends, and what the models say

Inbound event
an email, its PDF attachments, a portal notice weeks later

TriageResult
`Model.structured_output`
a classification, read as data, never as a rule

Document text
pdfplumber, one page at a time. Instructions inside it stay inert.

PlannerIntent
`Model.structured_output`
one proposed tool call. A proposal, not an order.

A model's output lands in the same zone as an attacker's document: typed, read, and gated like any other input.

TRUSTED

Dispatch — entry, and where a reopened case rejoins the graph

Triage LLM — classify into typed Case fields. Nova Micro

Evidence — read, extract, validate, promote. No model reads it.

Plan LLM — propose exactly one next action. Nova 2 Lite

Gate — execute, ask a human, or send the planner back

Execute — dispatch the tool. Two gates below it, both independent.

Verify — performed equals authorised, then read the world back

denied: replan, told a ReasonCode and nothing else

`GraphBuilder · every node subclasses MultiAgentBase · bounds from set_max_node_executions, set_execution_timeout, set_node_timeout`

Caregiver
approve or reject. The only other source of TRUSTED there is.

PolicyEngine one engine, one rules.yaml, three call sites

ALLOW · DENY · REQUIRE_HUMAN, deterministic, deny by default
rules are declarative in rules.yaml, never encoded in Python
argument classes belong to the tool registry: DESTINATION, AUTHORITY, VALUE
what the model is told back: a closed ReasonCode, never interpolated

`BeforeToolCallEvent.cancel_tool`

`@gated_tool wrapper (backstop)`

Two independent points at the tool boundary. Each is proven sufficient alone; with neither, the attack lands.

Application code, the policy engine and rules.yaml. TRUSTED is never manufactured by validation: it comes from configuration a person wrote, or a person pressing approve.
Case is frozen and transition() is its only writer, so DONE is reachable only from VERIFYING. No graph edge leaves DONE; only an inbound event can.

validated facts, with provenance ↓

↑ resolved trust is what the engine reads

OUTSIDE CARELOOP

demoworld/ — its own process, its own port. It may never import careloop, which is what makes reading it back evidence rather than the agent consulting itself.

`GET /clinic/slots`
the read-back: a separate request, compared against what policy authorised — never the booking's own response

`POST /clinic/appointments`
the one real external effect, carrying the idempotency key derived from (case_id, action, canonical args)

The other three effects — send_email, upload_document, grant_portal_access — are simulated, and verification of those closes the loop on the decision, not on the world.

CONTROLLED what validation has earned the right to promote, and nothing more

Fact
`{source_doc, page, trust_level}`
Promoted UNTRUSTED to CONTROLLED by validation, and only VALUE-class arguments are promotable at all. DESTINATION and AUTHORITY never are, whatever a validator says.

Case
Frozen. State, evidence, approvals, actions, and an append-only timeline of what was proposed, what was allowed or denied, which rule matched, and what verification observed.

CaseStore
SQLite here, a DynamoDB-shaped interface. The durable source of truth. Strands session persistence holds execution context only and is never asked a business fact.

DEPLOYED everything above runs in one process on one host; the clinic runs in another

Browser — the dashboard, polling /api/cases

CloudFront — HTTPS, and one origin so no CORS

EC2 t4g.small two processes, two ports, two failure domains

- **uvicorn :8000** — the graph above, /api/*, the built frontend
- **demoworld :8100** — /clinic/*, reachable by a judge

Amazon Bedrock — Nova Micro (triage), Nova 2 Lite (planner)

AgentCore Runtime — deployed, invoked, measured: 6.47 s cold, 0.72 s warm. Not on the production path — ADR 0002.

/ and /api/* to :8000 · /clinic/* to :8100

instance profile, no keys on the box

Zone colours are claims about authority, not about code quality: UNTRUSTED means nothing here may decide anything, whoever wrote it.